

PLAN DE CONFORMITÉ

RGPD

Association des Professionnels de la Sécurité de l'Information du Congo

Document interne — Version 1.0 — Août 2026

Objet : Mise en œuvre du règlement général sur la protection des données (UE 2016/679) au sein de l'association APSI-CG.

© APSI-CG — Tous droits réservés.

Ce document est mis à jour en fonction de l'évolution du site et du référentiel juridique.

Sommaire

1. Contexte, objectifs et champ d'application
.....
2. Cadre juridique applicable
.....
3. Responsable de traitement & Délégué à la protection des données
.....
4. Registre des traitements
.....
5. Finalités, bases juridiques et durée de conservation
.....
6. Cookies et technologies de suivi
.....
7. Sous-traitants et destinataires
.....
8. Transferts internationaux
.....
9. Mesures de sécurité
.....
10. Droits des personnes
.....
11. Gestion des demandes d'exercice de droits
.....
12. Notification des violations de données personnelles
.....
13. Formation et sensibilisation
.....
14. Plan d'actions d'implémentation
.....
15. Annexe — Mentions légales et politique de cookies
.....

1. Contexte, objectifs et champ d'application

APSI-CG (Association des Professionnels de la Sécurité de l'Information du Congo) traite des données à caractère personnel recueillies via son site internet (<https://apsi-cg.org>), son formulaire de contact, sa newsletter, ses inscriptions aux formations et son espace d'administration.

Ce plan de conformité a pour objectif de garantir le respect du RGPD (Règlement (UE) 2016/679) et de la loi française Informatique et Libertés (n°78-17) dans tous les traitements de données personnelles mis en œuvre par l'association, qu'ils soient opérés sur le site ou dans le back-office administratif.

Champ d'application : l'ensemble des traitements portant sur des données à caractère personnel de toute personne physique (visiteurs, prospects, membres, participants aux formations, partenaires).

- Principe de licéité, loyauté et transparence : l'information est claire et accessible.
- Principe de finalité : les données sont utilisées aux seules fins déclarées.
- Principe de limitation de la conservation : les données sont gardées le temps nécessaire.
- Principe du moindre effort : seules les données nécessaires sont collectées.

2. Cadre juridique applicable

Le traitement des données personnelles par APSI-CG s'inscrit dans le respect des textes suivants :

- Règlement (UE) 2016/679 du Parlement européen et du Conseil, du 27 avril 2016 (RGPD).
- Loi française n°78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés.
- Articles 43-1 et suivants du Code de la propriété intellectuelle et des libertés numériques.

L'absence de certification spécifique ne décharge pas APSI-CG de l'obligation de conformité. Le Délégué à la protection des données (DPD) veille au respect de ce référentiel.

3. Responsable de traitement & Délégué à la protection des données

Le responsable de traitement est l'Association des Professionnels de la Sécurité de l'Information du Congo.

Représentant légal

: Murphy SEMO — Président

Siège social

: Avenue Amílcar Cabral, Centre-ville — Brazzaville, République du Congo

Téléphone

: +242 06 123 45 67

E-mail du responsable

: contact@apsi-cg.org

E-mail du DPD

: dpo@apsi-cg.org

Site web

: <https://apsi-cg.org>

Le Délégué à la Protection des Données (DPD) est désigné par le bureau de l'association. Il est le point de contact privilégié des personnes et des autorités. Toute demande relative à la protection des données peut lui être adressée à l'adresse suivante : dpo@apsi-cg.org.

4. Registre des traitements

APSI-CG tient un registre des traitements mis en œuvre. Celui-ci est mis à jour à chaque évolution du site ou de l'organisation.

ID

Finalité du traitement

Données collectées

Base juridique

T02

Newsletter & alertes

E-mail, source du consentement, IP, date de
souscription/désabonnement

Consentement (art. 6.1.a)

T03

Inscriptions aux formations

Nom, prénom, e-mail, téléphone, organisation,
profil, notes, consentement RGPD

Exécution d'un contrat (6.1.b) +
consentement (6.1.a)

T04

Gestion des membres & cotisations

Nom, prénom, e-mail, téléphone, profession,
société, statut, montants, dates

Exécution d'un contrat d'adhésion
(6.1.b) + obligation légale (6.1.c)

T05

Projets collaboratifs (admin)

Identifiant membre, messages internes

Intérêt légitime (6.1.f)

T06

Journalisation & logs serveur

Adresse IP, journaux d'accès, user-agent

Intérêt légitime à la sécurité (6.1.f)

T07

Gestion des documents (archivage)

Titre, fichier, métadonnées, auteur

Exécution d'un contrat / intérêt légitime

T08

Facturation

Numéro de facture, montant, dates, identifiant membre

Obligation légale (6.1.c)

T09

Suivi de consentement aux cookies

Catégories de cookies acceptées, IP, user-agent, horodatage

Obligation légale de preuve du consentement (art. 7)

5. Finalités, bases juridiques et durée de conservation

Chaque traitement repose sur une base juridique distincte. Le consentement n'est jamais le seul fondement et peut être révoqué librement.

- Exécution d'une prestation précontractuelle : gestion des demandes de contact et d'inscription aux formations.
- Exécution d'un contrat : gestion des membres, cotisations et factures.
- Obligation légale : conservation des pièces comptables et factures (10 ans).
- Consentement explicite : newsletter, publicités ciblées, cookies analytiques/marketing.
- Intérêt légitime : sécurité des environnements, logs applicatifs, gestion collaborative.

Les durées de conservation sont indiquées dans le registre des traitements (section 4) et revues annuellement.

6. Cookies et technologies de suivi

Le site APSI-CG utilise les catégories de cookies suivantes, gérées via bannière de consentement et tableau de gestion :

- Cookies strictement nécessaires (session, consentement) : déposés sans consentement.
- Cookies d'analyse & mesure d'audience (Plausible Analytics) : activés sur décision explicite.
- Cookies de marketing & réseaux sociaux : activés sur décision explicite uniquement.

Le consentement est enregistré (audit trail) dans la table dédiée `consents` avec l'adresse IP, le user-agent et l'horodatage. L'utilisateur peut revenir sur son choix à tout moment via le lien 'Gestion des cookies' présent dans le pied de page.

7. Sous-traitants et destinataires

APSI-CG ne vend pas les données à caractère personnel. Les données ne sont communiquées qu'aux destinataires suivants :

- Les équipes autorisées de l'association (accès restreint par identifiants forts).
- Le prestataire d'hébergement OVHcloud (France), agissant sur instruction et lié par contrat de sous-traitance (art. 28).
- Le prestataire d'envoi de newsletter le cas échéant, lié par contrat de sous-traitance limité à l'envoi.

Tout sous-traitant est lié à APSI-CG par un contrat couvrant les garanties de sécurité et les obligations du

RGPD (articles 28 et 30).

8. Transferts internationaux

Les données sont hébergées en France auprès d'OVHcloud, dont le siège est en Europe. Aucun transfert vers un pays tiers n'est prévu. Le cas échéant, APSI-CG s'assurerait de garanties adéquates (clauses contractuelles types ou adéquation de l'État).

9. Mesures de sécurité

APSI-CG applique un ensemble de mesures techniques et organisationnelles proportionnées au risque :

- Chiffrement TLS (HTTPS) pour toutes les communications.
- Hachage bcrypt des mots de passe administrateurs (jamais en clair).
- Accès au back-office protégé par JWT + authentification forte (middleware requireAuth).
- Limitation des droits via un contrôle d'accès (admin seulement).
- Sauvegardes régulières et journalisation des accès.
- Gestion des vulnérabilités : dépendances tenues à jour (npm audit).
- Principe du moindre privilège appliqué aux comptes service.

Toute violation de données est évaluée à la lumière d'une matrice de risques actualisée chaque exercice.

10. Droits des personnes

Conformément aux articles 15 à 22 du RGPD, chaque personne dispose des droits suivants :

- Droit d'accès : connaître les données vous concernant que nous traitons.
- Droit de rectification : corriger des données inexacts.
- Droit à l'effacement (droit à l'oubli) : demander la suppression.
- Droit à la limitation du traitement.
- Droit à la portabilité des données : recevoir vos données dans un format structuré.
- Droit d'opposition : vous opposer à tout traitement (notamment la newsletter).
- Droit de ne pas faire l'objet d'une décision automatisée.
- Droit de retirer votre consentement à tout moment, sans affecter la licéité du traitement antérieur.
- Droit d'introduire une réclamation auprès de l'autorité de contrôle (CNIL).

Pour exercer ces droits, adressez votre demande (avec une copie d'une pièce d'identité et l'adresse e-mail concernée) au DPD : dpo@apsi-cg.org.

11. Gestion des demandes d'exercice de droits

Les demandes d'exercice de droits sont traitées sous 1 mois (RGPD art. 12.3), renouvelable par 2 mois motif légitime. APSI-CG a mis en place les mécanismes suivants :

- Droit d'accès & de portabilité : consultation des messages et abonnements par adresse e-mail via /api/contact/access/:email (public).
- Droit à l'effacement : suppression des messages de contact et désinscription de la newsletter via /api/contact/erase/:email (public).
- Droit de désabonnement : désinscription instantanée via le lien présent dans chaque e-mail de newsletter et via /api/newsletter/unsubscribe/:email.
- Droit de rectification : les mentions de contact sont modifiables directement sur demande au DPO.

Chaque demande est consignée dans le registre des demandes (horodatage, nature, réponse) pour assurer la traçabilité.

12. Notification des violations de données personnelles

Toute violation de données personnelles est détectée, documentée et notifiée :

- Notification à l'autorité de contrôle dans les 72 heures (RGPD art. 33).
- Communication aux personnes concernées lorsque la violation est de nature à engendrer un risque élevé pour leurs droits (art. 34).
- Registre des violations tenu par le DPO (date, heures, données, conséquences, mesures correctrices).

13. Formation et sensibilisation

Tous les membres du bureau et les intervenants accèdent à une formation à la protection des données à leur intégration. Une mise à jour est organisée chaque année. Le plan de conformité est revu chaque exercice par le DPO et le bureau.

14. Plan d'actions d'implémentation

Le respect du RGPD a été intégré techniquement dans le site web APSI-CG. Les actions d'implémentation suivantes ont été réalisées :

- Bannière de consentement aux cookies : le composant CookieConsent s'affiche sur chaque visite tant qu'aucun choix n'est enregistré. Propose 'Tout accepter', 'Tout refuser' et 'Gérer'. Le choix est persisté dans le stockage local.
- Gestion fine des cookies : trois catégories gérées (Nécessaires toujours actifs, Analyse, Marketing) avec un modal de gestion disponible depuis le pied de page.
- Checkbox de consentement explicite : formulaire de contact et inscription newsletter exigent une case non précochée ; même exigence sur le formulaire d'inscription aux formations.
- Traçabilité du consentement : chaque consentement est enregistré dans la table consents (IP, user-agent, horodatage) via l'endpoint /api/consents.
- Formulaire de contact soumis au RGPD : les messages sont stockés dans contact_messages avec les consentements explicites (consent_contact, consent_newsletter).
- Newsletter à double garde : l'inscription via /api/newsletter exige le consentement ; désabonnement permanent via /api/newsletter/unsubscribe/:email.
- Droits d'accès et d'effacement : endpoints publics /api/contact/access/:email et /api/contact/erase/:email permettent l'exercice de ces droits sans authentification.
- Pages juridiques : création des pages Politique de confidentialité (/politique-confidentialite), Gestion des cookies (/cookies) et Mentions légales (/mentions-legales), accessibles depuis le pied de page.
- Sécurité applicative : HTTPS obligatoire, mots de passe en bcrypt, JWT signés, express-rate-limit, helmet et cors configurés.

15. Annexe — Mentions légales et politique de cookies

Résumé des mentions légales du site :

- Éditeur : Association des Professionnels de la Sécurité de l'Information du Congo (APSI-CG).
- Hébergeur : OVHcloud — 2 rue Kellermann, 59100 Roubaix, France.
- Directeur de la publication : Murphy SEMO.
- Cookies : seules les catégories déclarées sont utilisées, sous consentement explicite.
- Propriété intellectuelle : tous les contenus sont réservés. Reproduction interdite sans autorisation.

Pour la version complète et en temps réel des mentions légales, politique de confidentialité et politique de cookies, consultez les pages publiques du site (pied de page).

Fin du document de conformité RGPD — APSI-CG, août 2026.